信息保护理论与技术 · 开卷考试终极全书

全考点精粹·课件四大章基础概念与定义·官方思考题标准答案·五大前沿顶会论文专题研读

【考场定位速查目录与题型映射指南】（遇到对应考点直接翻阅对应章节）

第1部分 第一章·网络空间与 AI 安全基础 P1 - P2

- 概念定义/四个层面/综合防范/三大威胁特征
- **AI 面临的五大安全挑战**（软硬件/完整性/保密性/鲁棒性/隐私）
- **AI 典型攻击方式**（闪避攻击/药饵攻击/后门攻击/模型窃取）
- **AI 安全防御手段与攻防架构**（云侧训练/业务部署/三维防御）
- **全周期防御策略**（训练阶段三大策略 / 使用阶段三大策略）
- **边缘智能五大安全问题**（设备/数据/系统与组件/接入/身份）
- **【官方思考题】**AI安全与传统三安全区别？切入点与体系化？

第2部分 第二章·安全服务、机制与访问控制模型 P2 - P4

- ISO 7498-2 五大安全服务与八大安全机制深度概念与映射
- P2DR 与 P2DR2 动态安全模型与数学判式推导
- 密码体制五元组与通信四大攻击形态
- **访问控制基本原理**（主体/客体/PEP/PDP引用监视器）
- DAC、MAC、RBAC（0-3族）、ABAC（四要素与四大实体）
- **BLP 机密性 vs Biba 完整性模型**偏序格对偶深度解析
- 形式化模型：Lampson矩阵、Graham-Denning 8原语、HRU定理、Take-Grant
- **【官方思考题】**老三样为何单一？为何缺乏系统内保护？

第3部分 第三章·可信计算技术及应用 P4 - P5

- 信息安全定义（静态/动态）、信息交换主要思想、本质内在缺陷
- 可信计算发展三阶段与可信 1.0/2.0/3.0 三代际演进
- 可信平台定义与三大特征（保护/证明/度量存储报告）
- 可信平台体系结构、TPM 芯片逻辑组件、TSS 四层协议栈
- **信任链技术**：RTM/RTS/RTR、无干扰理论、PCR 扩展公式
- **远程证明两阶段**（身份证明 / 日志与PCR校验）及 TNC 架构
- **机密计算对比**：Intel SGX (Enclave/EPC) vs ARM TrustZone
- 典型案例：龙芯可信、龙蜥 OS、海光平台、TIPU 可信智算板卡
- **【官方思考题】**数据空间作用？价值可信与信息环路保障？

第4部分 第四章·安全检索技术 (SE) P5 - P6

- HBC 诚实但好奇模型、PIR / SPIR / ORAM 核心机理与对比
- 密文检索系统模型与四元组算法（Setup, BuildIndex, Trapdoor, Search）
- **SSE 三大路线**：全文扫描(Song)、布隆过滤器、倒排索引(最优)
- 安全性定义演进：IND2-CKA 到适应性语义安全 (AS)
- **PEKS 三大主流**：BDOP (双线性)、KR (DDH)、DS (二次剩余)
- 前向安全 (Forward Privacy)、后向安全、保序加密 (OPE)
- **【官方思考题】**安全定义演进动因？拓扑关系保护与反制？

第5部分 第五部分·五篇学术前沿高分论文专题 P6 - P8

- 论文1：SneakyPrompt 文生图大模型越狱与安全过滤器突破
- 论文2：AgentDoS 智能体资源滥用 DoS（三大生命周期/模糊测试）
- 论文3：间接提示词注入攻击与防御基准（USENIX Security 2024）
- 论文4：区块链安全漏洞预演与抢先救援（FORAY 与 STING）
- 论文5：微信小程序生态安全：逆向解包、白盒敏感信息审计

第一章 网络空间与人工智能安全基础

1.1 网络空间安全基本概念与全局目标

- **网络空间安全定义：**网络空间是人类运用信息通信技术系统进行交互的空间。网络空间安全涉及在网络空间中的电子设备、电子信息系统、运行数据、系统应用中存在的安全问题，分别对应四个层面：**设备安全、系统安全、数据安全、应用安全**。
- **安全整体目标：**第一，防治、保护、处置涵盖互联网、电信网、广电网、物联网、工控网、计算/通信/控制系统及其承载数据不受损害；第二，防止对信息通信技术系统的滥用所引发的政治安全、经济安全、文化安全、国防安全。因此必须采取**法律、管理、技术、自律**等综合手段应对，绝非单纯技术手段。
- **网络安全三大现状威胁特征：**① 攻击侧目的专一，具备政治和经济目的，瞄准重要设施、重点单位与重大事件；② 网络信息安全和信息保护严重不对称；③ 数据泄漏（数据隐私）已从个人隐私上升为影响国家安全的重大问题。

1.2 人工智能系统在设计上面临的五大安全挑战（华为AI安全白皮书）

- **1. 软硬件安全：**在软件及硬件层面（应用、模型、平台、芯片），编码均可能存在漏洞或后门，使攻击者实施特权攻击。在模型层面上，攻击者可在模型中植入神经后门；由于 AI 模型的不可解释性，植入的恶意后门极难被静态审计检测。
- **2. 数据完整性：**在数据层面，攻击者能在训练阶段掺入恶意毒化数据，削弱破坏模型推理泛化能力；攻击者亦可在推理判断阶段加入人眼难以察觉的微小噪声（对抗样本），刻意扭曲输出判定。
- **3. 模型保密性：**在模型参数层面，服务提供者往往仅希望提供 MaaS 查询 API，而不希望泄露权重。但通过多次有针对性的输入输出查询，攻击者能够构建出高仿真的替代模型，实施模型逆向工程与参数盗取。
- **4. 模型鲁棒性：**训练模型时的样本往往覆盖性不足，决策边界拟合脆弱；面对分布外（OOD）恶意样本或长尾现实物理扰动时，模型无法给出正确鲁棒的判定结果。
- **5. 数据隐私：**在用户提供训练数据的场景下，攻击者能够通过反复查询已训练模型的置信度输出，推断特定训练数据成员身份（成员推断攻击），甚至逆向重构训练集中的敏感用户隐私。

1.3 人工智能安全典型攻击方式

推理攻击 **闪避攻击 (Evasion Attacks / 对抗样本)**

定义：在测试/推理阶段，通过修改输入样本，诱导 AI 模型产生错误识别。

- **对抗样本基本前提：**在原始良性样本上叠加人类不易察觉的微小扰动（$x^* = x + \delta$），诱导模型产生预测偏差。Szegedy 等人在 2013 年最早提出。Carlini & Wagner 提出的 **CW 攻击**可在微小扰动下达到 100% 攻击成功率并绕过防御。
- **物理世界攻击：**如在路标实体表面粘贴涂改贴纸，使算法将“禁止通行”误判为“限速45”，需抵抗缩放、旋转、光照与噪点变换。
- **黑盒迁移性 (Transferability)：**对一个模型生成的对抗样本往往能欺骗结构不同的另一模型（只要训练数据分布相似）。攻击者通过频繁 API 查询训练本地“替代模型”，以替代模型生成对抗样本即可发起黑盒攻击。

训练攻击 **药饵攻击、后门攻击与模型窃取**

- **药饵攻击 (Poisoning / 投毒攻击)：**在训练样本中掺入少量恶意标注或精心优化的噪声样本，大幅干扰模型最终分类边界与泛化精度。分为最优坡度攻击、全局最优攻击、统计优化攻击。
- **后门攻击 (Backdoor Attacks)：**在神经网络中植入特定神经元/权重模式生成后门模型。模型对正常输入的判定与原模型高度一致，但**当且仅当输入中出现攻击者预设的特定“触发器 (Trigger)”（如特定字符、水印、句式）时，输出会被强制操纵为攻击者预设的目标标签。**
- **模型/数据窃取攻击 (Model Extraction)：**攻击者通过查询接口分析输入输出置信度分布与响应时间等侧信道信息，推测系统模型内部超参数、网络架构与训练私密数据。

1.4 人工智能安全防御手段与攻防架构图解

AI 体系化防御由“攻防安全、模型安全、架构安全”三大支柱构建：

- **攻防安全层：**针对四大攻击部署专用算子——防闪避攻击、防药饵攻击、防后门攻击、防模型窃取。
- **模型安全层：**推动数据可解释、模型可验证性、模型健壮性（鲁棒性提升）与可解释模型。
- **架构安全层：**在 AI 云侧训练与端侧业务部署中，构建前馈检测与后馈检测双环路；引入**多模型异构表决架构**，结合冗余度检测与置信度熔断机制；确保数据跨层自洽性。

模型安全性三大判定准则：模型可检测性（能否查出受污染）、模型可验证性（行为是否可形式化规约证明）、模型可解释性（内部决策权重是否能被人类语义认知）。

1.5 全生命周期防御策略（训练阶段 vs 使用阶段）

训练阶段 **源头治理三大策略**

1. **数据验证与核实：**通过自动化与人工手段检查训练数据的不一致性、离群异常值和错误标签，清洗过滤恶意药饵。
2. **数据安全存储：**采用密码学加密、细粒度访问控制和安全传输通道，防止第三方训练外包过程中的非法篡改。
3. **模型验证与集成：**在不同隔离数据子集上训练多个异构基模型并集成表决，提高对单点数据投毒的容错抗性。

使用阶段 **运行推理三大策略**

1. **输入检查和清理：**对用户请求执行自动化清洗、敏感词过滤与语义重构，防止提示词注入（Prompt Injection）与对抗扰动。
2. **访问控制：**基于调用频率限制（Rate Limit）与鉴权凭据，防止通过密集爆破查询窃取模型参数。
3. **输出过滤和清理：**在内容生成后部署独立审核分类器，拦截违规有害输出，减轻下游业务逻辑漏洞。

1.6 边缘智能 (Edge Intelligence) 的安全问题

边缘智能定义：从中心化数据中心或云端迁移到网络边缘设备（基站、网关、车载终端、智能传感器）的就近智能化数据收集、缓存、处理和分析过程。具有本地决策、低时延响应特性，但暴露出严重的五大安全短板：

1. **边缘节点的设备安全：**参与实体类型繁多、体量庞大，物理环境开放。设备常部署在无防护的户外路由器、路侧单元，极易遭受直接物理接触、硬件逆向调试、侧信道分析或恶意节点伪装诱捕。
2. **边缘节点的数据安全：**
   - 数据损失：缺少中心化的高可用备份、容灾与审计机制，攻击者可通过恶意断电或删除数据销毁攻击痕迹，工业场景下直接引发决策停机。
   - 数据泄露：边缘节点采集第一手原始敏感数据（视频流、人脸、位置轨迹），普遍缺乏强加密脱敏芯片，易发生数据外泄。
3. **边缘节点的系统与组件安全：**固件裁剪定制缺乏规范，易调用被供应链污染的第三方软硬件模块；系统接口缺乏完整性校验与计算结果准确性证明，API 设计复杂但忽视了安全鉴权。
4. **边缘接入安全：**轻量级处理器算力微弱，难以支持高开销密码算法与深度防火墙；云-边通信多基于追求高吞吐的消息中间件（如 MQTT/Overlay 协议），忽视了传输机密性、完整性与抗抵赖性。
5. **身份认证安全：**加密运算外包导致凭证管理碎片化；难以在大规模、异构、动态拓扑的分布式边缘设备间构建跨域统一的身份认证与高效密钥分发；远程场景下策略更新同步滞后。

官方思考题 1 **为什么当前 AI 安全受到学术界与工业界的空前关注？AI 安全和数据安全、系统安全、应用安全有何本质区别?**

标准答题要点：① 关注动因：关键基础设施深度依赖（自动驾驶、医疗、金融控制权移交）；深度学习追求经验风险最小化，假定“独立同分布（IID）”且处于良性环境，未将对抗样本纳入理论边界；模型参数海量且黑箱不可解释，难以静态审计后门。② 本质区别：传统系统安全关注软硬件代码与协议漏洞（防非授权利用）；AI 安全是在**代码与系统完全正常、无漏洞**的前提下，模型因内在泛化拟合脆弱性而给出致命错误判定。传统数据安全保护存储与传输的机密性与防篡改（CIA）；AI 数据安全强调**语义层面的真实性与分布对抗**，肉眼不可见扰动即可诱发误判。传统应用安全防范 SQL 注入等语法逻辑穿透；AI 应用安全防范**认知逻辑与语义劫持**（如提示词注入、越狱、对抗性迁移）。

官方思考题 2　AI 安全可能的防御手段与切入点有哪些？应如何构建体系化防御？

标准答题要点：构建全生命周期“数据—模型—架构”三维协同防御：① 数据侧：训练前离群点清洗与自洽性核对杜绝药饵；采集训练中结合差分隐私（DP）阻断成员推断；② 模型侧：开展对抗训练（将对抗样本引入 Min-Max 极大极小博弈优化以拓宽鲁棒边界）；通过神经元剪枝消除隐蔽后门通道；借助模型蒸馏压缩敏感奇异特征；③ 系统架构侧：输入端引入去噪与超分辨率重构；输出端部署敏感词与格式过滤器；构建多模型异构冗余交叉验证架构，发生显著判定分歧时即时熔断阻断服务。

第二章 信息安全基础理论、机制与访问控制模型

2.1 ISO 7498-2 安全服务与安全机制深度定义与映射关系

安全服务定义：由系统各层协议提供、用以保证数据处理和传输具备足够安全性的核心安全防护措施。ISO 7498-2 确立了**五大类安全服务**：

- **(1) 鉴别服务 (Authentication)：**证实实体身份及数据源真实性。分为**实体鉴别**（防冒名连接）与**消息鉴别**（防篡改伪造）。信息的完整性主要通过鉴别服务完成。
- **(2) 访问控制 (Access Control)：**决定谁能够通过何种方式使用系统的什么资源（计算、存储、网络、物理资源）。
- **(3) 数据机密性 (Confidentiality)：**确保数据不被非授权泄露。保护手段分为：隐含语义（数据加密）、访问控制隔离、分割与散布存储。
- **(4) 数据完整性 (Data Integrity)：**确保数据未丢失、未篡改、未非授权插入或重放。分为单个单元完整性与数据单元流完整性。保障过程涵盖：防护（生成受约束数据）、证实（检测校验）、保护（重新生成数据）。
- **(5) 抗抵赖 (Non-repudiation)：**防止参与通信的实体否认其行为。分为**带数据原发证明的抗抵赖**（防发信人抵赖）与**带交付证明的抗抵赖**（防收信人抵赖）。

安全服务 (Service)	支撑该服务的安全机制 (ISO 7498-2 八大安全机制)
实体鉴别 (Peer Entity Authen.)	加密机制 (Y)、数字签名机制 (Y)、鉴别交换机制 (Y)
数据源鉴别 (Data Origin Authen.)	加密机制 (Y)、数字签名机制 (Y)
访问控制 (Access Control)	访问控制机制 (Y)（访问控制矩阵/列表、权标、安全标签、时间/路由控制）
机密性 (Confidentiality)	加密机制 (Y)、路由控制机制 (Y)（选择安全物理链路）
业务流机密性 (Traffic Flow Conf.)	加密机制 (Y)、业务填充机制 (Y)（伪造虚假数据流量防流量分析）、路由控制 (Y)
数据完整性 (Data Integrity)	加密机制 (Y)、数字签名机制 (Y)、数据完整性机制 (Y)（哈希散列与消息认证码 MAC）
抗抵赖 (Non-repudiation)	数字签名机制 (Y)、数据完整性机制 (Y)、公证机制 (Y)（引入可信第三方 TTP 权威仲裁证明）
可用性 (Availability)	数据完整性机制 (Y)、鉴别交换机制 (Y)

2.2 动态安全模型与判定公式 (P2DR / P2DR2)

核心模型　P2DR 动态模型

核心思想：以**策略 (Policy)** 为核心，防护 (Protection)、检测 (Detection)、响应 (Response) 动态协同联动。

安全充要充填判定公式：

$$t_P > (t_D + t_R)$$

- t_P：系统防护机制抵御入侵所能维持的有效安全时间。
- t_D：检测系统发现攻击所需时间；t_R：响应处置生效时间。

物理意义：唯有防护时间大于检测与响应时间之和，才能确保攻击被处置在造成实际破坏之前。

弹性演进　P2DR2 模型

演进动因：面对 APT 与勒索病毒，绝对的阻止并不存在。当系统防护被突破（$t_P \le t_D + t_R$）时，必须依靠**恢复与重建 (Recovery)** 机制，使业务在容忍时延内自动回滚基线并恢复可用，构建系统级**弹性韧性 (Cyber Resilience)**。

密码五元组模型：(M, C, K, E, D)。

- 对称密码：$K_e = K_d$（AES/DES/SM4），效率高。
- 非对称密码：$K_e \neq K_d$（RSA/ECC/SM2），解耦身份认证。

2.3 访问控制基本原理与四大核心模型 (DAC, MAC, RBAC, ABAC)

基本原理：主体 (Subject) 向访问控制实施功能 (PEP) 提交访问请求，PEP 请求访问控制决策功能 (PDP) 进行裁决，PDP 依据安全策略库给出允许/拒绝判定，PEP 强制执行。引用监视器 (Reference Monitor) 确保所有访问操作无法被绕过、具备可自防范性且可形式化验证。

DAC　自主访问控制 (Discretionary Access Control)

- **机理：**资源创建者拥有客体属权，可自主将该对象的读写执行权限授予或从其他用户收回。
- **实现载体：**访问控制矩阵 (ACM)、访问控制列表 (ACL)。
- **致命缺陷：**权限过大易误泄密；ACL 庞大难维护；**对特洛伊木马 (Trojan) 完全脆弱**（合法用户运行木马后，木马继承该用户的完整特权将敏感文件转存，DAC 无法辨别操作者意图）。

ABAC 基于属性的访问控制 (Attribute-Based)

- **四要素：**主体属性（部门/职级）、客体属性（密级/类别）、操作权限属性（读/写/删）、环境属性（时间/IP/风险）。
- **四大架构实体：**
  - **PEP：**策略执行点，拦截原始请求并执行决策。
  - **PDP：**策略判定点，根据策略集判定并返回结果。
  - **PAP：**策略管理点，负责策略的创建、维护与下发。
  - **AA：**属性权威，负责实体属性的注册、维护与查询。

MAC 强制访问控制：BLP 与 Biba 模型对偶深度对比

标记体系： $Label = <Level, Category>$。支配关系：$A\ dom\ B \Leftrightarrow Level_A \geq Level_B \text{ 且 } Category_A \supseteq Category_B$。

模型名称	核心目标	简单安全特性 (读)	* 特性 (写)	信息流动方向
BLP 模型	**机密性** 防信息泄露	**下读 (No Read Up)：** $Label_S\ dom\ Label_O$ 允许读	**上写 (No Write Down)：** $Label_O\ dom\ Label_S$ 允许写	**单向向上流：** 信息只能从低密级流向高密级
Biba 模型	**完整性** 防数据篡改污染	**上读 (No Read Down)：** $Label_O\ dom\ Label_S$ 允许读	**下写 (No Write Up)：** $Label_S\ dom\ Label_O$ 允许写	**单向向下流：** 信息只能从高完整性流向低完整性

注：Biba 还具有**调用特性**：主体 S_1 仅在 $Label_{S1}\ dom\ Label_{S2}$ 时才可调用 S_2。

RBAC 基于角色的访问控制模型族 (NIST)

- **解耦机制：**用户与角色多对多 (UA)，角色与权限多对多 (PA)，通过**会话 (Session)** 动态激活。
- **层级演进：**
  - **$RBAC_0$ (Core)：**最小核心集合（用户、角色、会话、权限）。
  - **$RBAC_1$ (Hierarchical)：**引入角色继承（Role Hierarchy）。
  - **$RBAC_2$ (Constrained)：**引入约束（静态/动态职责分离 SSD/DSD）。
  - **$RBAC_3$ (Unified)：**综合继承与约束的集大成模型。

2.4 经典形式化安全模型理论

模型名称	核心定义与数学基础	核心机制与操作规则
Lampson 访问矩阵	三元组保护状态：(S, O, M)，主体集 S，客体集 O，矩阵 M	所有主体对客体的存取必须经由引用监视器强制仲裁；系统状态的转移表现为矩阵单元内容的变化。
Graham-Denning	引入属主 (Owner) 与控制者 (Controller) 角色，可传递权限标为 $r*$	**8 大基本保护权原语：**创建客体、创建主体、删除客体、删除主体、读访问权、删访问权、授权访问权、转让访问权。
HRU 模型	基于条件判定与 6 种原子操作语句的命令形式体系	**核心定理：**一般访问控制系统的“安全性 (Safety Problem，判断权限是否会意外泄露)”在通用图灵机上是**算法不可判定 (Undecidable)** 的。
Take-Grant 模型	基于有向图的有穷状态转移系统，边带标签 $r, t\ (take), g\ (grant)$	**4 种原子图操作：**Create（增节点边）、Revoke（删边标签）、Take（掠取目标节点的权限）、Grant（将自身拥有的权限授予目标节点）。

第二章 · 官方思考题 传统防火墙、杀毒软件、入侵检测“老三样”为何手段单一？为何访问控制和密码学方法只能抵御非授权用户的非法访问，缺乏系统内保护能力？

标准答题要点：① “老三样”单一根源：高度依赖先验已知特征码与静态五元组规则库，假定“外紧内松”，面对未知 0-day、无文件攻击与内部越权天然存在滞后与防御盲区；② 缺乏系统内保护能力的机理：传统 DAC 仅识别外部登录凭证，缺乏细粒度行为语义判定；合法用户本地运行木马后，木马**直接继承该合法用户的完整权限**发起恶意读写，OS 无法识别该操作是出于真实意图还是木马操纵。传统密码学（AES/RSA）只能保护“静态存储 (Data-at-Rest)”和“传输 (Data-in-Transit)”；当数据进入内存进行“使用计算 (Data-in-Use)”时必须解密为明文，一旦内核或拥有 Root 权限的组件失陷，数据在明文状态下毫无自卫能力。

第三章 可信计算技术及应用

3.1 信息安全内涵、信息交换思想与系统缺陷

- **信息安全定义与内涵：**系统中包含两种形态信息：① 静态信息：存储在计算节点上，未被非法读取或修改即为安全；② 动态信息：在节点中运行或网络间传播，**信息处理的实际效果与用户预期的结果一致**即为安全。安全内容涵盖：**物理安全、软件安全、数据安全。**
- **信息交换的主要思想：**在开放不可信的物理通信通道中，依托密码变换与可信第三方（TTP 仲裁/密钥分发），使通信双方在遭遇主动/被动对手干扰下仍能建立机密、完整、可认证与抗抵赖的安全信道。
- **信息系统的三大缺陷：**① 本质缺陷：信息的开放性与安全性的内在矛盾；人工智能泛化性与系统可信性的冲突；② 内在缺陷：硬件受温湿度/电磁干扰的老化失效；软件设计疏忽留下的逻辑漏洞；网络协议缺陷（如 TCP 三次握手易遭 SYN Flood 拒绝服务攻击）；③ 外在缺陷：攻防不对称对抗；传统密码与访问控制缺乏计算态系统内保护能力。

3.2 可信计算的形成发展与三代演进特征

发展历程：1985 年美国国防部颁布《TCSEC》（橘皮书）确立可信计算基 (TCB) 概念；1999 年 IT 业界逐步认可硬件安全模块构想；2001 年 TCPA 提出 TPM 1.1 标准；2009 年 4 项核心规范成为 ISO/IEC 11889 国际标准；2015 年升级至 TPM 2.0。我国技术经历了**消化吸收 (2000-2005)**、**自主创新与标准 TCM 制定 (2006-2007)**、**产业化推广 (2008 至今)** 三大阶段。

代际演进	防护核心特性	保护对象	系统架构结构	核心机理	体系形态
可信 1.0 (主机)	主机可靠性	计算机硬件部件	冗余备份	故障诊查	容错算法（TCSEC 准则）
可信 2.0 (PC)	节点安全性	PC 单机为主	功能附加模块	被动度量	TPM / TCM + TSS 软件栈
可信 3.0 (网络)	系统免疫性	节点虚拟动态链	宿主 + 可信双节点	主动免疫	可信免疫架构 (TPCM)

3.3 可信计算平台定义、三大特征与体系结构

- **可信计算平台定义：**能够提供可信计算安全服务的计算机软硬件综合实体，对外提供平台完整性报告、平台身份认证、基于可信硬件模块的数据保密等安全服务。**基本思想：**首先构建一个硬件信任根，再建立一条信任链，从信任根到硬件平台、操作系统、应用程序，一级认证一级，一级信任一级，把信任扩展到整个计算环境。
- **可信计算平台三大基本特征：(1) 保护能力；(2) 证明能力；(3) 完整性度量、存储和报告。**
- **可信计算平台四层体系结构：**硬件层（自主 CPU + CRTM + 可信安全芯片 TPM/TCM + 可信 BIOS） $ o$ 核心层（可信芯片驱动） $ o$ 服务层（可信服务程序 TSM/TSS） $ o$ 应用层（密码学服务与完整性度量接口）。

3.4 可信芯片硬件结构与 TSS 软件栈体系

硬件层 **TPM 安全芯片逻辑组件**

- **I/O 组件：**通过 LPC/SPI/UART 总线实现外部与 TPM 交互。
- **密码协处理器：**硬件加速 RSA/ECC/国密 SM2/SM3/SM4。
- **HMAC / SHA1 / SHA256 引擎：**计算抗碰撞散列。
- **随机数发生器 (RNG)：**提供硬件级物理熵源。
- **非易失性存储 (NVRAM)：**永久固化背书密钥 (EK) 与状态。
- **易失性存储器：**包含一组平台配置寄存器 (PCR)。

软件层 **TSS / TSM 软件栈四层协议架构**

1. **TSP (服务提供者层)：**向顶层应用提供标准化 TSPI 接口。
2. **TCS (核心服务层)：**在系统进程中提供 TCSI 接口，管理密钥缓存、同步资源访问。
3. **TDDL (设备驱动库层)：**提供 TDDLI 接口，作为用户态到内核驱动的调用桥梁。
4. **TDD (设备驱动层)：**位于 OS 内核，提供 TDDI 接口直面硬件总线。

3.5 信任链技术、度量传递与 PCR 扩展公式

三大信任根体系：RTM (度量根，CRTM) 负责计算度量；**RTS (存储根)** 隔离保存度量值；**RTR (报告根)** 签名出具证明报告。

信任链逐级扩展： *CRTM → BIOS → BootLoader (GRUB) → OS Kernel → App*。前一级在执行前严格度量后一级并记录，实现一级信任一级。基于无干扰理论模型（域 u 的动作不影响域 v 的输出，则 u 对 v 无干扰）。

PCR 扩展计算公式（只增不减、单向雪崩）：

$$PCR_{new} = Hash(PCR_{old} \,||\, MeasureData)$$

重要机理：PCR 寄存器严禁直接覆写（Overwrite）。一旦系统中某一步骤加载了被篡改的模块，异常哈希混合后在数学上**绝对不可逆，永远无法通过后续执行任何操作将 PCR 伪造回干净合法的基线值**。

3.6 远程证明协议双阶段流程与 TNC 架构

证明协议 **远程证明两阶段**

- **阶段一：设备身份鉴别：**客户端出示背书证书 EK_{cert} 与鉴别公钥 AK_{pub}；服务端用厂商根 CA 验签，并用 EK_{pub} 加密随机挑战 *Secret* 发回，客户端用内部 EK_{priv} 解密返回，证实芯片物理真实性。
- **阶段二：完整性日志与 PCR 校验：**客户端 TPM 使用 AK_{priv} 对当前 PCR 进行签名产生 **Quote**，连同事件日志 (Event Log) 返回；服务端本地**重放 (Replay)** 日志计算 PCR 最终值，比对通过则判定系统环境干净合规。

接入架构 **可信网络连接 (TNC)**

分为三层：① **网络访问控制层**（传统 802.1X/VPN 连接）；② **完整性评估层**（TNC 客户端与服务端依策略评估状态）；③ **完整性度量层**（IMC 搜集平台度量，IMV 执行核验）。

典型案例简述：

- 龙芯/海光：全国产 CPU 挂载 TCM/TPCM 芯片，自底向上构建软硬件全栈国密链。
- *TIPU* 可信智算板卡：基于 FPGA+SoC 架构，实现数算分离机密计算与用户态加密文件系统 (UeFS)。

3.7 现代机密计算技术深度对比：Intel SGX vs ARM TrustZone

对比维度	Intel SGX (Software Guard Extensions)	ARM TrustZone
基本设计思路	面向**进程/容器级**构建隔离执行环境（Enclave 飞地），以硬件保障用户空间机密计算	面向**全系统 SoC 级**切分安全世界 (Secure) 与非安全世界 (Normal)，实现时分物理级隔离
硬件隔离实体	**PRM (处理器保留内存)** 与 **EPC (Enclave 页缓存)**，内存加密引擎 (MEE)	总线安全位控制 (NS bit)、安全外设控制器 (TZPC)、安全内存控制器 (TZASC)
上下文切换	专用特权指令：*EENTER, ERESUME, EEXIT* 进入或退出保护容器	通过硬件特殊模式：**Monitor Mode (安全监控模式)** 进行双世界上下文切换
对 OS 的信任	**Zero-Trust OS**：完全不信任 OS/Hypervisor，内核被攻陷仍无法偷窥 Enclave 明文	信任安全世界操作系统 (Secure OS)；仅普通世界 (Rich OS) 与安全世界单向隔离

第三章 · 官方思考题 1 & 2 & 3　可信计算技术在信息空间中的作用是什么？信息自身的“价值可信”如何保障？对构建未来高效信息环路有何帮助？

标准答题要点：① 在信息空间的作用：解决计算环境真实性验证基石（平台完整性度量）；实现密态数据与安全基线的强绑定（数据封印/解封，PCR 不符合预期基线绝不释放密钥）；打造跨机构跨域分布式协同互信（远程证明支持“数据可用不可见”）。② 保障信息自身“价值可信”：源头采用数字签名、区块链分布式账本与时间戳确权溯源；流转处理中引入零知识证明（ZKP）保证衍生计算真伪；算法端部署自洽性规则检验，剔除恶意投毒伪造。③ 赋能高效信息环路：消除多主体跨域协作摩擦，支撑微秒级自动清结算；在车联网、无人调度等自主闭环系统中，杜绝因虚假信息引起“错误正反馈放大”导致系统灾变。

第四章 安全检索技术 (Searchable Encryption) 核心理论

4.1 基本概念与诚实但好奇 (HBC) 模型

- **外在攻击者 vs 合法好奇者：**传统外在黑客依靠漏洞注入或爆破；云端好奇者掌握合法物理存储介质、算法透明且掌握全部数据流。
- **诚实但好奇 (Honest-but-curious, HBC) 威胁模型：**云服务器严格遵守既定检索协议流程（不故意破坏或丢弃数据），但会主动搜集、记录所有查询中间视图，并利用背景知识推断用户的**敏感数据明文与真实查询意图**。
- **安全检索核心目标：**在将密文存储与检索运算外包给不可信云服务器的同时，**同时保护数据机密性与查询机密性**。

4.2 早期安全检索技术对比：PIR, SPIR, ORAM

公开库　PIR (隐私信息检索) 与 SPIR

- **PIR (Private Information Retrieval)：**面向**公开数据库**。允许用户检索并获取数据 x_i，但服务器**完全无法获知用户查询的具体数据索引** i（任意两次查询在服务器视角的概率分布完全不可区分：$Pr[View(i)] = Pr[View(i')]$）。
- **SPIR (对称 PIR)：**双向保护，在 PIR 基础上增加限制——**用户除了获得请求的 x_i 之外，无法探知数据库中其他任何数据内容**（保护数据库所有者版权）。

私密库　ORAM (不经意随机访问机)

- **定位：**面向**加密私密数据库**。其核心目标是在读写过程中向服务器彻底隐藏用户的**访问模式 (Access Pattern)**。
- **访问模式包含：**操作是读还是写、访问的物理内存地址、数据块内容与访问频度。
- **机理：**通过多轮客户端本地混淆、树状打乱与地址重映射，使得对于任意两组访问序列 Y, Y'，服务器观测到的物理存取特征完全不可区分。

4.3 密文检索系统模型与四元组算法

三大角色：数据所有者 (DO)、数据检索者 (DU)、云服务器 (Server)。

四大标准算法：① *Setup*：生成主密钥与安全公共参数；② *BuildIndex*：DO 为明文构建加密检索索引并加密数据上传；③ *GenTrapdoor*：DU 生成检索关键词对应的加密陷门 (Trapdoor / 搜索凭证) 发往云端；④ *Search*：云端输入索引与陷门执行密态匹配，输出匹配文档密文集合。

对称 (SSE) vs 非对称 (PEKS)：SSE 场景中 DO 与 DU 为同一方，私钥构建索引与陷门，高效；PEKS 场景中任何人可利用公钥加密构建索引（多写），仅持有私钥者可生成陷门（单读）。

4.4 对称密文检索 (SSE) 三大经典技术路线对比

方案路线	核心数据结构与机理	检索复杂度	优缺点与适用场景
基于全文扫描 (Song 等人方案)	流密码与伪随机异或分组；密文包含 $(S_i, F_{ki}(S_i)) \oplus (L_i, R_i)$ 结构，云端用陷门逐词异或验证	$O(N)$ 与全库字数及文档长度严格线性相关	**优点：**无需预先建立庞大索引。**缺点：**检索极慢，不适用大规模系统。
基于文档-关键词索引 (布隆过滤器)	为每篇文档构建布隆过滤器位数组 $BF(D)$；哈希映射将命中位置 1；引入双重伪随机映射消除跨文档相关性	$O(\|D\|)$ 与全库文档总篇数严格线性相关	**优点：**易于文档动态增删更新。**缺点：**存在**假阳性误报率 (False Positive)**。
基于关键词-文档索引 (倒排链表 + 查找表)	构建全局数组 A 与查找表 T；将各包含关键词的文档 ID 串联成加密指针链表；陷门直接命中首节点沿链解密	$O(\|D(w)\|)$ **仅与实际命中的文档数量线性相关**	**目前工业界最高效体系**；检索耗时与全库规模解耦，支持海量大数据。

4.5 非对称公钥可搜索加密 (PEKS) 三大主流方案精要

方案名称	数学基础与安全假设	密文索引与陷门生成形式	通信量与计算复杂度
BDOP-PEKS (Boneh 等)	基于 BF-IBE 体系；安全性归结为 **BDH (双线性 Diffie-Hellman)** 困难假设	• 索引：$C_i = (g^r, H_2(e(H_1(w_i), h^r)))$ • 陷门：$T_w = H_1(w)^\alpha$	通信量为 $\|g\|$，服务器检索需计算 **1 次双线性配对 (Pairing)**。
KR-PEKS (Katz 等)	基于 KR-IBE 体系；安全性归结为标准 **DDH (判定性 DH)** 困难假设（无需配对）	利用多项式系数编码多维特征：$C = (u_1, u_2, e, v_w)$；无双线性运算开销	通信量为 $6\|g\|$，搜索效率提高至常数级 $O(1)$，但索引体积偏大。
DS-PEKS (Di Crescenzo)	基于**雅可比符号 (Jacobi)** 与模合数下的**二次剩余问题 (QR)** 难解性	将关键词逐比特映射至伪随机二次剩余元序列：$s = (s_1, ..., s_{4k})$，陷门提取平方根	完全摆脱高成本椭圆曲线配对，但密文长度和检索时间与关键词长度线性膨胀。

4.6 安全性定义演进、前向安全与保序加密 (OPE)

安全等级 **从 IND2-CKA 到适应性语义安全 (AS)**

- **泄露要素：访问模式** $\alpha(H)$（命中物理地址序列）；**搜索模式** $\delta(H)$（两次查询是否同词的对称矩阵）。
- **安全强弱阶梯：**
  $IND\text{-}CKA < NS$ (非适应性语义安全) $= NI < AI \leq AS$ (适应性语义安全)。
  - 非适应性：敌手在看到密文与索引前必须提前选定全部查询词。
  - 适应性：敌手根据前一次返回的命中文档与陷门，自适应调整下一轮查询词，更贴近实战。

动态与区间 **前向安全性与保序加密**

- **前向安全性 (Forward Privacy)：**向系统**动态插入新增密文数据时，服务器无法利用历史查询陷门，判定新数据是否匹配此前的关键词**。缺乏前向安全的方案易遭受**恶意文件注入攻击 (File Injection Attacks)**，攻击者注入约 10 个特定密文即可推断出历史查询关键词明文。
- **保序加密 (OPE)：**$x < y \Rightarrow Enc(x) < Enc(y)$。保持数值明文顺序，直接支持云端 B+ 树范围与区间检索，但在具备背景知识的敌手面前易受频度分析泄露。

第四章 · 官方思考题 **密文检索安全性定义演进的动因是什么？关键词与文档间的拓扑关系是否受到保护？如何保护？**

标准答题要点：① 演进动因：IND2-CKA 仅孤立分析索引，忽视了检索时陷门与索引联合暴露的信息；非适应性（NS）假设敌手提前选定查询词，而现实诚实但好奇（HBC）服务器会根据上一轮命中文档自适应设计下一轮陷门，因此必须演进至适应性语义安全（AS）。② 拓扑关系受保护现状：绝大多数现有高效方案（倒排索引、多关键词）**均未保护该拓扑关系**！服务器可通过统计命中文档重叠度与访问/搜索模式，结合外部公开语料库发起频度推断攻击（Count Attacks）破译关键词明文。③ 深层保护手段：结合 ORAM 消除物理访问模式、注入伪造假查询填充流量、或将倒排检索逻辑下沉至 Intel SGX 等硬件 TEE 中执行。

第五部分 五大前沿学术顶会与技术分享论文深度专题

前沿论文 1 **SneakyPrompt: Jailbreaking Text-to-image Generative Models（文生图大模型越狱攻击）**

- **背景与痛点：**文生图模型（Stable Diffusion, DALL·E 2）部署安全过滤器（Safety Filter）防范 NSFW。传统文本对抗攻击迁移至图像生成存在三大痛点：**丢失目标图像视觉语义、在线查询成本过高、随机种子导致生成的对抗 Prompt 无法重复利用（Re-use）**。
- **核心机制（强化学习引导搜索）：**
  ① 威胁模型：黑盒闭包访问目标文生图模型 M（仅能输入 Prompt，无梯度与中间特征），无限制白盒访问本地影子文本编码器 E。
  ② 攻击管道：首先识别敏感 Token 集合 W（利用敏感词表或基于分类器扰动贡献度 ε 排序），再在词表 D 中施加长度约束 l 缩小搜索空间 S。
  ③ 基于强化学习（RL）的引导式搜索：相比暴力搜索、贪心和束搜索，SneakyPrompt-RL 设计了策略网络。若通过过滤器，以生成图像与原语义嵌入的余弦相似度作为正向奖励；未通过则分配惩罚。以极低查询代价实现 100% 单次绕过与近 70% 的高复用率。
- **★ 考场预测题：试论述文生图模型安全过滤器的工作原理，并分析 SneakyPrompt 为何能绕过黑盒过滤器同时保留图像原语义？**
  答题核心：阐明文本侧过滤（关键词/文本分类）、图像侧过滤（图像NSFW分类）以及联合检测（CLIP图文语义相似度阈值）；指出过滤器的本质是建立语义高维超平面判定边界；论述 SneakyPrompt 利用强化学习在“绕过安全判定边界”与“维持文本编码器高维视觉特征距离”之间求得最优解，以无害扰动 Token（如 "mambo incomplete clicking" 代替 "naked"）成功诱导扩散模型合成目标视觉特征。

前沿论文 2 **AgentDoS: Detecting Denial-of-Service Vulnerabilities in LLM-based Agents（智能体资源耗尽 DoS）**

- **核心矛盾：**大模型智能体自主性（Autonomy）与资源治理边界（Governance）冲突。开发者为了维持长文本连贯性倾向于保留上下文与中间文件，缺乏全局配额管控。
- **资源三大生命周期与攻击窗口（核心必背考点）：**
  - **短生命周期（Short-lived）：**单轮交互或函数结束即释放（如局部变量）。攻击策略：单次请求注入超大载荷或深层循环（如超大压缩包/深层嵌套解析），把瞬时**峰值占用** m_m 推到极限拉爆内存。
  - **长生命周期（Long-lived）：**跨多轮会话保留，会话结束才释放（如对话上下文、会话运行日志）。攻击策略：在**同一会话内部**持续交互，使残留占用 m_e 逐轮累积直至耗尽。
  - **全生命周期（Full-lifecycle）：**跨会话残留且永不自动释放（如工具落盘文件、后台总日志）。攻击策略：**跨会话重复新建 session**，绕过单会话轮数上限，无限制向磁盘堆积垃圾文件。
- **★ 考场预测题：传统 DoS 与 Agent 拒绝服务漏洞在攻击入口与防御上有何不同？为什么传统限流机制无法防范 AgentDoS？**
  答题核心：传统 DoS 发送大量畸形网络请求；AgentDoS 提交的是**语义合法且看起来正常的自然语言任务**，攻击被“转委托”给 Agent 自主工具链；单次请求合规，但利用未设清理策略的全生命周期资源跨会话堆积；攻击者只需新建 Session 即可规避单会话轮数限制，通过切片多次下载规避大小限制；必须实装“三重配额方案”（单次文件上限 100MB + 目录累计上限 1GB + 任务结束自动清理目录）。

前沿论文 3 Formalizing and Benchmarking Prompt Injection Attacks and Defenses（间接提示词注入基准）

- **本质根源：**传统系统在语法层面实现了代码与数据的强隔离（如 SQL 参数化查询）；而在 LLM-Integrated 架构中，系统指令 s_t 与外部不可信数据 x_t 均以同质的自然语言输入，**指令与数据的信任边界彻底失效**。
- **五种代表性注入攻击构造：**
  ① *Naive*：直接拼接；② *Escape*：转义字符伪造截断；③ *Context Ignoring*：显式插入 "Ignore previous instructions"；④ *Fake Completion*：伪造 "Answer: task complete." 诱导开启新任务（单项最强）；⑤ *Combined*（组合攻击）：换行 + 伪造完成 + 忽略上下文全面融合（GPT-4 上 ASV 达 0.75）。
- **★ 考场预测题：试从安全工程角度论述为何间接提示词注入攻击极难根治？现有预防型与检测型防御各自的致命瓶颈是什么？**
  答题核心：大模型无法区分 Control Plane（控制面）与 Data Plane（数据面）。预防型防御（改写 Paraphrasing）以**严重破坏模型正常任务性能（PNA-T 暴跌）**为代价；检测型防御（PPL 困惑度）因注入文本本身自然流畅而出现**极高漏报率**；当前技术不存在兼顾“高防御、零误报、不损功能”的有效防御。

前沿论文 4 区块链安全中的漏洞预演与抢先救援（FORAY 与 STING：把攻击转化为防御）

- **核心背景：**DeFi 业务逻辑漏洞频发（“账本每一步都记对了，但钱依然丢了”）。利用闪电贷在单一原子交易内操纵预言机价格或绕过资产销毁验证。
- **两阶段防御闭环时间线：**
  - **事前预演 (FORAY - ACM CCS 2024)：**上线前建立代币流图 (TFG) 与金融操作语法 (AFL)，将攻击合成抽象为“草图生成（骨架）+ 约束求解（填充金额）+ CEGIS 验证反馈”，提前暴露逻辑漏洞。
  - **事中抢先救援 (STING - USENIX Security 2023)：**在攻击交易于 Mempool 广播但尚未打包确认的极短窗口期，自动合成反制合约抢先打包执行 (Front-running)，将受害资金转入安全防御者账户。
- **★ 考场预测题：论述智能合约“闪电贷攻击”的金融机理，并分析 STING 机制如何在 Mempool 争夺战中实现资产抢先救援？为什么简单照抄黑客交易必然失败？**
  答题核心：阐述闪电贷无抵押借贷操纵流动性池价格差的机理；指出直接照抄必然失败的根本原因在于黑客部署了**控制流保护 CFFP**（校验 `tx.origin == 黑客`）与**数据流保护 DFFP**（收款地址硬编码），直接重放会触发 revert 或帮黑客送钱；STING 必须通过动态污点分析重写反制合约并提高 Gas 抢先打包。

前沿论文 5 基于小程序安全信息攻击与保护（微信小程序生态逆向与敏感常量审计）

- **攻击面演变：**小程序在宿主沙箱（WeChatAppEx）中运行。攻击者利用客户端逆向破解与本地代码解密，将外部网络黑盒发包彻底转化为**本地白盒代码审计**。
- **解密与解包全流程：**Frida 内存注入修改 `enable_vconsole: true` 开启 DevTools；解密 .wxapkg（PBKDF2 派生 AES 密钥解密前 1023 字节 + AppID 倒数第 2 字符异或解密剩余数据）；反编译还原 `app-service.js`（核心逻辑）与 `app-config.json`（配置路由）。
- **★ 考场预测题：试论述微信小程序中 AppSecret 泄露所导致的安全危害，并从架构设计角度给出彻底根治此类密钥泄漏的防御方案。**
  答题核心：AppSecret 为小程序平台级最高特权凭证，一旦泄露，攻击者可在无需用户参与的情况下调用微信后台 API 获取全局 access_token，接管小程序身份、批量爬取用户 OpenID 与敏感 PII、甚至篡改支付回调；防御必须严格确立**“前端零信任”**准则，严禁前端硬编码高权限密钥，所有第三方鉴权必须经由安全后端网关（BFF 架构）中转，前端仅持有短期时效 SessionToken。